

Informe CMMC.

La CMMC es ya un marco global de referencia para medir la “higiene” ciber de las cadenas de suministro, aunque haya nacido pensando en los contratistas del DoD estadounidense. Desde 2025, el foco se ha desplazado claramente desde el “tener controles” al “poder medir, demostrar y comparar” madurez mediante indicadores y métricas cuantificables, algo muy útil si uno quiere jugar en ligas nacionales en España bajo el paraguas NIS2, DORA y el ecosistema INCIBE-CCN-CNC.12345

1. Breve recordatorio: qué es realmente CMMC 2.0 (y por qué importa en España)

- La Cybersecurity Maturity Model Certification (CMMC 2.0) es un estándar unificado de ciberseguridad del Departamento de Defensa de EE. UU. (DoD) para asegurar la información sensible (FCI y CUI) en la Base Industrial de Defensa (DIB).641
- CMMC 2.0 simplificó el modelo original de cinco niveles a tres niveles: Nivel 1 (Fundacional, 17 prácticas básicas), Nivel 2 (Avanzado, 110 controles NIST SP 800-171) y Nivel 3 (Experto, 110 controles de 800-171 más medidas adicionales de 800-172).27895
- A partir de 2025, CMMC 2.0 se introduce gradualmente como requisito contractual obligatorio en los contratos del DoD, con despliegue completo previsto hacia 2028.1011

¿Por qué pinta algo esto en España, tierra de NIS2, ENS y DORA? Porque:

- La industria española exportadora, aeroespacial, TIC y de defensa que quiera estar (o seguir) en la cadena de suministro del DoD tendrá que “hablar CMMC” con fluidez.1110
- CMMC reusa NIST SP 800-171/172 y se alinea con el NIST Cybersecurity Framework 2.0, muy presentes ya en estrategias nacionales europeas y en guías de operadores esenciales bajo NIS2.83122
- Es un marco de madurez orientado a evaluación, con scoring explícito (SPRS) y métricas de cumplimiento que encajan bien con enfoques actuariales de riesgo y benchmarking entre organizaciones.1348

1 <https://netwrix.com/es/resources/blog/what-is-cmmc/>

2 https://dodcio.defense.gov/Portals/0/Documents/CMMC/ModelOverview_V2.0_FINAL2_20211202_508.pdf

3 <https://compliancehub.wiki/span-cybersecurity-and-data-prviacy-with-gdpr-and-lopdgdd-synergy/>

4 <https://www.gsa.gov/blog/2026/02/12/get-to-know-the-cybersecurity-maturity-model-certification>

5 <https://it.uw.edu/policies/compliance/cybersecurity-maturity-model-certification-cmmc/>

2. Núcleo duro: familias de requisitos y tipos de indicadores que exige CMMC

CMMC no define un “cuadro de mando” numérico oficial, pero sí fija qué se debe hacer (prácticas) y con qué profundidad (procesos/madurez) dentro de 14 familias NIST SP 800-171. A partir de ahí, la medición es inevitable.⁶⁷⁸

2.1. Las 14 familias (y qué se suele medir)

Las 14 familias de NIST SP 800-171 que CMMC 2.0 toma como base para Nivel 2 son, en síntesis: control de acceso, concienciación y formación, auditoría y responsabilización, seguridad de configuración, identificación y autenticación, respuesta a incidentes, mantenimiento, protección de medios, protección física, personal, recuperación, seguridad de comunicaciones, seguridad de sistemas y desarrollo, y gestión de riesgos.⁹¹⁰¹¹¹²

Para cada familia, en la práctica, se acaban usando métricas como:

- Porcentaje de controles implementados y eficazmente operativos (por familia y global).
- Densidad de eventos/alertas por tipo de activo (usuarios, endpoints, servidores, aplicaciones críticas).
- Tiempos de ciclo: detección, contención, erradicación, recuperación.
- Cobertura de formación (por rol) y efectividad (resultados de simulaciones de phishing, exámenes, ejercicios rojos).
- Grado de automatización: porcentaje de controles monitorizados de forma continua frente a muestreo manual.¹⁴¹⁵⁴⁸

2.2. SPRS: el corazón cuantitativo

El Supplier Performance Risk System (SPRS) es la pieza más “numérica” de la película: el DoD asigna una puntuación a la posición de seguridad de cada contratista.¹³

6 <https://it.uw.edu/policies/compliance/cybersecurity-maturity-model-certification-cmmc/>

7 https://dodcio.defense.gov/Portals/0/Documents/CMMC/ModelOverview_V2.0_FINAL2_20211202_508.pdf

8 <https://isidefense.com/blog/how-nist-800-171-and-cmmc-work-together>

9 <https://peakinfosec.com/whitepapers/nist-sp-800-171-and-cmmc-level-2-assessment-scoping-infographic-whitepaper/>

10 https://dodcio.defense.gov/Portals/0/Documents/CMMC/ModelOverview_V2.0_FINAL2_20211202_508.pdf

11 <https://isidefense.com/blog/how-nist-800-171-and-cmmc-work-together>

12 <https://it.uw.edu/policies/compliance/cybersecurity-maturity-model-certification-cmmc/>

13 <https://testpros.com/cybersecurity-compliance/cmmc-vs-nist-800-171/>

- El SPRS se calcula generalmente a partir del cumplimiento NIST SP 800-171 (110 requisitos) con una escala que va de -203 a +110.13
- Cada control no implementado o sólo parcialmente implementado descuenta puntos; alcanzar +110 implica cumplir todos los requisitos de NIST SP 800-171.713
- Esta puntuación impacta directamente en la elegibilidad para contratos y forma un indicador compuesto de madurez que combina controles técnicos, procesos de gestión y documentación (SSP, POA\&M).141113

Aunque el SPRS esté pensado para la DIB, conceptualmente es exportable como:

- Índice nacional sectorial (ej. “Índice de Madurez Ciber Industrial España” basado en un subconjunto adaptado de NIST 800-171/ENS).
- Métrica de riesgo actuarial para fijar primas de ciberseguro, garantías financieras y límites de responsabilidad.

3. Tendencias 2025+ en indicadores CMMC (con vocación mundial)

Desde 2025 se observan varias tendencias claras en cómo se diseñan y usan los indicadores vinculados a CMMC en empresas, universidades e informes industriales.141516171819

3.1. Del “checklist” al scoring dinámico y continuo

- Crece el énfasis en la monitorización continua para satisfacer controles de evaluación (CA) de NIST SP 800-171 y CMMC Nivel 2, con guías específicas para “continuous monitoring” publicadas en 2026.15
- Las organizaciones avanzadas ya no se conforman con una foto cada tres años: usan paneles que recalculan su “puntuación CMMC/NIST” en tiempo casi real, integrando hallazgos de vulnerabilidades, configuraciones y eventos.121514
- Se pasa de indicadores binarios (sí/no) a curvas de madurez: porcentaje de hosts con agentes EDR activos, porcentaje de cuentas con MFA robusta, antigüedad media de los parches críticos, etc.81512

14 <https://www.gsa.gov/blog/2026/02/12/get-to-know-the-cybersecurity-maturity-model-certification>

15 <https://blogs.cisco.com/industries/strengthening-cybersecurity-cmmc-with-ciscos-nist-cybersecurity-framework-2-0-mapping>

16 <https://isidefense.com/blog/how-nist-800-171-and-cmmc-work-together>

17 <https://www.kiteworks.com/es/cumplimiento-de-cmmc/hoja-de-ruta-cmmc-tu-guia-definitiva-para-el-cumplimiento-de-cmmc-2-0/>

18 <https://www.exostar.com/blog/cmmc-compliance/navigating-cmmc-2-0-and-nist-sp-800-171-your-comprehensive-system-security-plan-ssp-guide/>

19 <https://testpros.com/cybersecurity-compliance/cmmc-vs-nist-800-171/>

3.2. Métricas alineadas con riesgo y amenazas avanzadas (Nivel 3)

- Nivel 3 incorpora controles de NIST SP 800-172 orientados a amenazas persistentes avanzadas (APT): monitorización de comportamiento, defensa activa, protección de tecnologías críticas.16171025
- Esto se traduce en indicadores como: número de intentos de intrusión altamente sofisticados detectados y frustrados, tiempo de detección de actividad anómala en cuentas privilegiadas, proporción de sistemas críticos con hardening reforzado.161012
- La medición ya no es sólo de “controles”, sino de “capacidad de resistencia”: métricas de resiliencia operativa (MTTR, tiempo máximo de indisponibilidad tolerable, degradación de servicios gestionada).1548

3.3. Enfoque en documentación, trazabilidad y “auditabilidad”

- El énfasis actual en System Security Plans (SSP) y Plan of Action and Milestones (POA\&M) convierte la completitud y calidad documental en indicadores explícitos.21478
- Informes industriales destacan una correlación entre la “documentación completamente formalizada” y el cumplimiento efectivo de estándares de cifrado, gestión de claves y segmentación.1814
- Muchas organizaciones definen KPIs como porcentaje de controles con evidencias actualizadas, medianas de antigüedad de evidencias, número de acciones POA\&M vencidas vs. completadas.1413

4. España: cómo se puede “territorializar” CMMC a nivel nacional

CMMC no es ni va a ser norma española, pero ofrece un patrón muy útil para construir un esquema de métricas aplicable a escala nacional, alineado con NIS2, ENS y DORA.2021

4.1. Ecosistema regulatorio y de referencia en España

- España ha traspuesto la Directiva NIS2 mediante una ley de coordinación y gobernanza de la ciberseguridad (en vigor desde 2025), creando un Centro Nacional de Ciberseguridad (CNC) y reforzando obligaciones de análisis de riesgo, medidas técnicas y reporte.3
- INCIBE impulsa programas de colaboración público-privada para reforzar ciberseguridad de pymes y sectores críticos; los reguladores sectoriales (BdE/CNMV/DGSFP para DORA, etc.) introducen requerimientos de resiliencia digital más cuantificables.3
- La Guía de Compliance de la CNMC se ha consolidado como estándar de referencia para evaluar eficacia de programas de cumplimiento, introduciendo lógicas de evaluación que podrían extrapolarse a ciberseguridad.19

Todo ello crea un terreno fértil para usar CMMC como plantilla de indicadores “duros” aplicables a:

20 <https://compliancehub.wiki/span-cybersecurity-and-data-prviacy-with-gdpr-and-lopdgdd-synergy/>

21 <https://www.cuatrecasas.com/es/spain/gobierno-corporativo-compliance/art/cnmc-guia-compliance-lustro>

- Operadores de servicios esenciales y entidades importantes NIS2.
- Pymes integradas en cadenas de suministro críticas.
- Universidades y centros de investigación con proyectos de defensa o alta sensibilidad.

4.2. Propuesta de taxonomía de indicadores CMMC “made in Spain”

Tomando las 14 familias CMMC/NIST y cruzándolas con las exigencias de NIS2/ENS/DORA, cabe estructurar un catálogo nacional de indicadores en tres niveles: organización, sector, país.

Una posible tabla de correspondencias simplificada:

Dimensión	Capa CMMC	Ejemplos de indicador propuesto España
Controles básicos	Nivel 1	% de empresas de un sector con MFA en accesos remotos críticos; % con backup probados trimestralmente.284
CUI / datos sensibles	Nivel 2	Media SPRS-like por sector (adaptada ENS/NIS2); % de entidades con cifrado fuerte de datos en reposo en sistemas críticos.1323
APT / crítica	Nivel 3	% de operadores esenciales con monitoreo continuo 24/7; tiempo medio de detección de incidentes significativos.1610315
Gestión de riesgo	Procesos	Porcentaje de entidades con mapa de riesgos ciber revisado al menos anual; integración del riesgo ciber en mapas corporativos.8319
Gobernanza	Procesos	% de juntas con reporte de ciber al menos trimestral; % con responsable de seguridad designado.319

4.3. Integración con métricas NIS2, DORA y ENS

- NIS2 exige a los Estados miembros estructuras de supervisión y reporting homogéneas, incluyendo métricas de incidentes, tiempos de respuesta y adopción de medidas de seguridad.3
- DORA refuerza la resiliencia operativa digital en el sector financiero con indicadores de continuidad, pruebas de resiliencia y gestión de proveedores TIC críticos.3
- El Esquema Nacional de Seguridad (ENS) ya utiliza categorías y medidas que se pueden mapear a los controles NIST 800-171/CMMC, facilitando el diseño de indicadores compatibles.3

Así, España podría razonablemente:

- Definir un “perfil CMMC-ENS” para sectores críticos, donde cada control tenga asociado al menos una métrica cuantitativa y un objetivo de madurez.
- Publicar, vía INCIBE/CNC, informes anuales de madurez sectorial, al estilo de un “SPRS nacional” anonimizado.

5. Ejemplos concretos de métricas CMMC adaptables al contexto español

5.1. Métricas técnicas clave por familia

A partir de NIST SP 800-171/CMMC, algunos indicadores técnicos “exportables” serían:2223242526

22 <https://blogs.cisco.com/industries/strengthening-cybersecurity-cmmc-with-ciscos-nist-cybersecurity-framework-2-0-mapping>

23 https://dodcio.defense.gov/Portals/0/Documents/CMMC/ModelOverview_V2.0_FINAL2_20211202_508.pdf

24 <https://peakinfosec.com/whitepapers/nist-sp-800-171-and-cmmc-level-2-assessment-scoping-infographic-whitepaper/>

25 <https://isidefense.com/blog/how-nist-800-171-and-cmmc-work-together>

26 <https://lakeridge.io/how-to-implement-continuous-monitoring-to-meet-nist-sp-800-171-rev2-cmmc-20-level-2-control-cal2-3123-a-practical-8-step-plan>

- Control de acceso
 - % de cuentas privilegiadas con autenticación multifactor fuerte.
 - Ratio de cuentas de servicio documentadas vs. detectadas.
 - Antigüedad máxima de contraseñas para cuentas sin MFA (o idealmente, inferir objetivo 0).
- Gestión de vulnerabilidades y configuración
 - Porcentaje de sistemas con parches críticos aplicados en menos de X días.
 - Número medio de vulnerabilidades críticas abiertas por activo.
 - Porcentaje de activos gestionados con configuración reforzada y monitorizada.
- Monitorización y respuesta a incidentes
 - Tiempo medio de detección (MTTD) de incidentes significativos.
 - Tiempo medio de respuesta (MTTR) hasta contención.
 - Porcentaje de incidentes con post-mortem formal y lecciones aprendidas implementadas.
- Protección de datos y cifrado
 - % de datos sensibles cifrados en reposo y en tránsito según estándares verificados.
 - Número de excepciones justificadas de cifrado por sistema crítico.
- Formación y concienciación
 - % de empleados que completan la formación anual; % de personal clave con formación avanzada.
 - Tasa de clics en simulaciones de phishing y evolución trimestral.
- % de cuentas privilegiadas con autenticación multifactor fuerte.
- Ratio de cuentas de servicio documentadas vs. detectadas.
- Antigüedad máxima de contraseñas para cuentas sin MFA (o idealmente, inferir objetivo 0).
- Porcentaje de sistemas con parches críticos aplicados en menos de X días.
- Número medio de vulnerabilidades críticas abiertas por activo.
- Porcentaje de activos gestionados con configuración reforzada y monitorizada.
- Tiempo medio de detección (MTTD) de incidentes significativos.
- Tiempo medio de respuesta (MTTR) hasta contención.
- Porcentaje de incidentes con post-mortem formal y lecciones aprendidas implementadas.
- % de datos sensibles cifrados en reposo y en tránsito según estándares verificados.
- Número de excepciones justificadas de cifrado por sistema crítico.

- % de empleados que completan la formación anual; % de personal clave con formación avanzada.
- Tasa de clics en simulaciones de phishing y evolución trimestral.

Estos indicadores, si se recogen de forma sistemática y anonimizada, permiten evaluar sectores (sanidad, energía, industria, administración pública) y compararlos con benchmarks internacionales basados en CMMC/NIST.

5.2. Métricas de madurez y gobernanza

- Porcentaje de prácticas CMMC/NIST implementadas, parcialmente implementadas, planificadas, no implantadas (mapa de calor de madurez).2814
- Score tipo SPRS adaptado (por ejemplo, de -X a +110) por organización y media sectorial.713
- Cobertura de proveedores críticos: % de contratos que incluyen cláusulas de requisitos mínimos alineados con CMMC/NIS2/DORA.113

6. España en el contexto internacional CMMC

En el plano comparado, se observan distintas aproximaciones:

- Universidades y centros de investigación en EE. UU. (ej. Northeastern, University of Washington) adoptan CMMC 2.0 para proyectos con CUI y definen rutas internas hacia Nivel 2 con gobernanza y métricas claras.205
- Grandes fabricantes de tecnología (Cisco, Microsoft Azure, etc.) publican mapeos entre sus plataformas, CMMC y NIST, aportando indicadores de referencia (grado de cobertura de controles, capacidades de monitorización continua).21812
- Proveedores y consultoras especializadas documentan procesos de evaluación y scoring (SPRS, gap analysis) que pueden servir como plantilla metodológica para una métrica europea.1114137

España, con un ecosistema público (INCIBE, CCN-CERT, CNC) y regulatorio ya maduro, tiene margen para:

- Adoptar explícitamente mapeos ENS/NIS2 ↔ NIST/CMMC para operadores esenciales, facilitando comparabilidad con socios internacionales.
- Emplear indicadores CMMC-like en evaluaciones de riesgos de terceros y programas de certificación sectoriales (por ejemplo, esquemas voluntarios de madurez ciber para pymes).

7. Sugerencias de preguntas e indicadores para una encuesta nacional CMMC-inspirada

Adaptando el espíritu CMMC a una encuesta de diagnóstico nacional para España, algunas preguntas (con respuestas tipo escala Likert o porcentajes) podrían ser:

1. Sobre gobierno y estrategia
 - ¿Dispone su organización de una estrategia formal de ciberseguridad aprobada por el máximo órgano de gobierno?
 - ¿Con qué frecuencia recibe el órgano de gobierno un informe de riesgos cibernéticos y madurez de controles?
2. Sobre controles técnicos alineados con CMMC/NIST
 - ¿Qué porcentaje aproximado de sus sistemas críticos se encuentra monitorizado en tiempo real mediante herramientas de detección de amenazas?
 - ¿Qué proporción de sus accesos remotos a sistemas críticos se protege con MFA robusta (no sólo OTP por SMS)?
3. Sobre gestión de vulnerabilidades y parches
 - ¿En qué plazo medio aplica su organización los parches críticos de seguridad en sistemas expuestos a internet?
 - ¿Qué porcentaje de activos está integrado en un inventario actualizado y con dueño asignado?
4. Sobre protección de información sensible
 - ¿Están cifrados en reposo los datos considerados sensibles o críticos para el negocio (o asimilables a CUI) en al menos el X % de sus sistemas?
 - ¿Tiene su organización políticas y controles técnicos para limitar la copia de dicha información fuera de entornos controlados?
5. Sobre respuesta a incidentes y resiliencia
 - ¿Dispones de un plan de respuesta a incidentes formalmente aprobado, probado al menos una vez al año mediante simulacros?
 - ¿Cuál fue el tiempo medio desde la detección hasta la contención del último incidente significativo?
6. Sobre proveedores y cadena de suministro
 - ¿Incluye su organización requisitos formales de seguridad (alineados con NIS2/DORA/CMMC-like) en los contratos con proveedores críticos?
 - ¿Evalúa periódicamente, con métricas estructuradas, la postura de seguridad de esos proveedores?

- ¿Dispone su organización de una estrategia formal de ciberseguridad aprobada por el máximo órgano de gobierno?
- ¿Con qué frecuencia recibe el órgano de gobierno un informe de riesgos cibernéticos y madurez de controles?
- ¿Qué porcentaje aproximado de sus sistemas críticos se encuentra monitorizado en tiempo real mediante herramientas de detección de amenazas?
- ¿Qué proporción de sus accesos remotos a sistemas críticos se protege con MFA robusta (no sólo OTP por SMS)?
- ¿En qué plazo medio aplica su organización los parches críticos de seguridad en sistemas expuestos a internet?
- ¿Qué porcentaje de activos está integrado en un inventario actualizado y con dueño asignado?
- ¿Están cifrados en reposo los datos considerados sensibles o críticos para el negocio (o asimilables a CUI) en al menos el X % de sus sistemas?
- ¿Tiene su organización políticas y controles técnicos para limitar la copia de dicha información fuera de entornos controlados?
- ¿Dispones de un plan de respuesta a incidentes formalmente aprobado, probado al menos una vez al año mediante simulacros?
- ¿Cuál fue el tiempo medio desde la detección hasta la contención del último incidente significativo?
- ¿Incluye su organización requisitos formales de seguridad (alineados con NIS2/DORA/CMMC-like) en los contratos con proveedores críticos?
- ¿Evalúa periódicamente, con métricas estructuradas, la postura de seguridad de esos proveedores?

Estas preguntas, debidamente normalizadas, pueden producir un índice compuesto de madurez inspirado en CMMC, comparable entre sectores y alineable con los requisitos de NIS2 y las mejores prácticas NIST.27282930

222324252627282930

27 <https://www.cuatrecasas.com/es/spain/gobierno-corporativo-compliance/art/cmmc-guia-compliance-lustro>

28 <https://isidefense.com/blog/how-nist-800-171-and-cmmc-work-together>

29 https://dodcio.defense.gov/Portals/0/Documents/CMMC/ModelOverview_V2.0_FINAL2_20211202_508.pdf

30 <https://compliancehub.wiki/span-cybersecurity-and-data-prviacy-with-gdpr-and-lopdgdd-synergy/>